

Bazaarjo Build Server SSH & Sudo Hardening Report

Submission by: Amnih Faraj Yousef

Email: amnih.yousef1@gmail.com

1. Introduction

Following Omar’s incident, Bazaarjo conducted a **manual security review** of the build server prior to deploying automated configuration management (SCM).

This assessment focuses on **SSH access controls, sudo privileges, and user/key hygiene**, aligned with **CIS Linux & CIS SSH benchmarks** to reduce lateral movement, privilege escalation, and unauthorized administrative access.

2. Task 1 – SSH & Sudo Misconfiguration Findings

2.1 Identified SSH & Sudo Misconfigurations

#	Misconfiguration	CIS Control Violated	Risk Impact
1	Root login allowed via SSH	CIS SSH 5.2.8	Enables direct admin compromise
2	Password-based SSH authentication enabled	CIS SSH 5.2.4	Credential stuffing & brute force risk
3	Over-broad SSH access (dev, tempuser, root)	CIS SSH 5.2.14	Lateral movement possible
4	No SSH user/group allowlist	CIS SSH 5.2.15	Unauthorized account persistence
5	Weak SSH session controls (default retries & timeouts)	CIS SSH 5.2.6	Increased attack window

6	Sudo configured with broad privileges	CIS Linux 5.3.4	Privilege escalation risk
7	User home directories writable by owner without restriction	CIS Linux 6.2.7	SSH key tampering
8	~/.ssh and authorized_keys permissions not enforced	CIS SSH 5.2.13	Key hijacking & persistence

2.2 SSH Login Scope Review

Observed SSH Access:

- root → SSH enabled (password-based)
- dev → SSH enabled (password-based)
- tempuser → SSH enabled (password-based)

Risk:

Temporary and admin accounts can be abused for **persistent access and lateral movement**.

2.3 Sudo Rights Audit

Observed:

- Users granted **broad sudo access**
- Sudo does **not require password**
- No command-level restrictions

Risk:

Any compromised user account becomes **full root immediately**.

2.4 User & Key Hygiene Issues

- ~/.ssh/ permissions not enforced
- authorized_keys writable by user
- No centralized control or auditing of SSH keys

Risk:

Attackers can inject or replace SSH keys for stealthy persistence.

3. Task 2 – Secure SSH Baseline (CIS-Aligned)

3.1 Secure SSH Configuration Baseline

Setting	Secure Value
RootLogin	PermitRootLogin no
Authentication	Key-based only
PasswordAuth	PasswordAuthentication no
Allowed Users	Explicit allowlist
SSH Protocol	Protocol 2 only
Weak Ciphers	Disabled
MaxAuthTries	3
LoginGraceTime	30 seconds
Idle Timeout	300 seconds
X11 Forwarding	Disabled

3.2 Enforced SSH Configuration (sshd_config)

```
PermitRootLogin no
PasswordAuthentication no
PubkeyAuthentication yes
AllowUsers dev
Protocol 2
MaxAuthTries 3
LoginGraceTime 30
ClientAliveInterval 300
ClientAliveCountMax 0
X11Forwarding no
AllowTcpForwarding no
```

3.3 Secure Sudo Baseline

Control	Secure Value
---------	--------------

Password required	Yes
Scope	Command-level only
Blanket ALL	Removed
File permissions	440

```
dev ALL=(ALL) /usr/bin/systemctl restart apache2
```

3.4 File & Key Permissions Enforcement

Path	Permission
/home/*	750
~/.ssh	700
authorized_keys	600

4. Verification Results (Evidence)

4.1 SSH Validation

✓ Root SSH blocked:

```
ssh root@localhost -p 2222
# Access denied
```

✓ Password authentication rejected:

```
ssh dev@localhost -p 2222
# Permission denied (publickey)
```

✓ Unauthorized user blocked:

```
ssh tempuser@localhost -p 2222
# Access denied
```

4.2 Crypto Validation

```
sshd -T | grep ciphers
```

✓ Only modern ciphers enabled

✓ Legacy algorithms removed

4.3 Sudo Validation

```
sudo su
```

✓ Password required

✓ Unauthorized commands denied

5. Remediation Summary

Issue	Fix Applied
Root SSH access	Disabled
Password authentication	Disabled
Over-broad SSH users	Restricted
Weak session controls	Hardened
Sudo overreach	Least privilege enforced
SSH key hygiene	Permissions corrected

6. Recommendations (Immediate Actions)

1. **Rebuild base images** with hardened SSH baseline baked in
2. **Rotate all SSH keys** and remove unused accounts
3. **Deploy centralized SCM** (Ansible) with continuous compliance checks

7. Conclusion

By manually enforcing a **CIS-compliant SSH and sudo baseline**, Bazaarjo significantly reduced the risk of **lateral movement, privilege escalation, and unauthorized administrative access**.

This hardened configuration provides a secure foundation before transitioning to automated SCM enforcement.